Rotina de verificação de segurança

Agrocel Certificados · o que olhar, com que frequência e quem faz · versão de 21 de outubro de 2026

1. Como funciona

A rotina tem duas partes que se completam. As duas existem para que um problema apareça logo, e não depois de um vazamento.

- [ ] **Verificação automática** (feita pelo desenvolvedor, com ajuda do Claude): roda 44 testes de acesso por perfil no ambiente de teste, compara as regras do banco real com as do teste, confere alertas do Supabase, usuários e o registro de atividade. Gera um relatório curto com o que está certo e o que precisa de atenção.
- [ ] **Checklist humano** (feito pelo administrador da Agrocel): o que só uma pessoa da empresa sabe, como quem saiu, quem ainda precisa de acesso e se algo no registro de atividade parece estranho.

2. Checklist por frequência

Toda semana

administrador da Agrocel · cerca de 10 minutos

- [ ] Abrir a aba **Registros** e ler o que aconteceu: exclusões, entradas em horários estranhos, mudanças em usuários. Algo que ninguém reconhece deve ser investigado na hora.
- [ ] Abrir a aba **Usuários**: alguém saiu da empresa ou não precisa mais de acesso? Desativar no mesmo dia.
- [ ] Perguntar aos técnicos se alguma visita ficou parada na aba **Pendentes** do celular. Visita parada é dado guardado no aparelho sem ir para o sistema.
- [ ] Conferir se há senhas provisórias que a pessoa nunca trocou. Pedir a troca em **Minha conta**.
- [ ] Exportar um backup em **Exportar dados** (JSON) e guardar fora do computador de uso diário.

Todo mês

desenvolvedor · cerca de 30 minutos

- [ ] Rodar os testes de acesso: `node supabase/testes-de-acesso.mjs`. Precisam passar todos (hoje 44 de 44).
- [ ] Rodar `supabase/verificar-projetos.sql` nos dois projetos e comparar. Se políticas, funções, gatilhos ou bucket forem diferentes, os projetos saíram de sincronia.
- [ ] Ver os alertas de segurança do Supabase (projeto real e teste) e tratar os que aparecerem.
- [ ] Conferir quantos administradores ativos existem. Recomendado: pelo menos dois, para não depender de uma única pessoa.
- [ ] Olhar o uso do Supabase (banco, arquivos, limites do plano) e o custo.
- [ ] Ver se as bibliotecas do app (Supabase, jsPDF, SheetJS) têm avisos de segurança novos. Elas ficam em `assets/vendor` (cópia própria) e não se atualizam sozinhas: ao trocar um arquivo, aumentar a `VERSAO` do `sw.js`.
- [ ] Rodar o teste do modo sem internet: `node supabase/teste-offline.mjs` (com o app servido em 127.0.0.1:8765).
- [ ] Conferir que o repositório público não tem chaves secretas (o teste de acesso já faz essa busca).
- [ ] Guardar o relatório do mês.

A cada três meses desenvolvedor e Fernando

- [ ] Revisar as pendências de LGPD: política de privacidade, base legal, prazo de guarda, canal para o titular. Marcar o que foi resolvido.
- [ ] Decidir o que apagar: cadastros antigos, fotos e ordens que passaram do prazo de guarda definido.
- [ ] Simulado de perda de celular: desativar o usuário, trocar senhas e conferir no registro que nada indevido aconteceu.
- [ ] Revisar quem tem acesso aos serviços: painel do Supabase, repositório no GitHub, e-mail do dono e domínio.
- [ ] Conferir se as contas do Supabase, do GitHub e do e-mail principal usam verificação em duas etapas.
- [ ] Testar a restauração de um backup no ambiente de teste (Exportar dados > Restaurar backup). Conferir que os dados voltam e que a restauração aparece no registro de atividade.

Antes de qualquer mudança no sistema real desenvolvedor

- [ ] Aplicar primeiro no ambiente de teste e rodar os testes de acesso.
- [ ] Só depois aplicar no real, com o mesmo SQL de `supabase/schema.sql`.
- [ ] Rodar a comparação dos dois projetos de novo e atualizar o `schema.sql` no repositório.

Quando acontecer gatilhos

Situação	O que fazer
Alguém sai da empresa	Desativar o usuário no mesmo dia. Se tinha senha de outras pessoas, trocá-las.
Celular perdido ou roubado	Desativar o usuário, redefinir a senha, olhar o registro de atividade do período.
Suspeita de acesso indevido	Desativar os usuários envolvidos, ler o registro, avisar o desenvolvedor. Se houve vazamento de dados pessoais, avisar os afetados e a ANPD no prazo legal (confirmar com advogado).
Cliente pede seus dados, correção ou exclusão	Atender pelo canal de contato. A exclusão é feita na aba Clientes e fica no registro.
Alerta novo do Supabase ou do GitHub	Ler no mesmo dia e decidir se vira correção.

3. Primeira verificação (21 de outubro de 2026)

Resultado da primeira rodada, feita no projeto real e no de teste.

Verificação	Resultado	Detalhe
Testes de acesso por perfil	OK	40 de 40 passaram: sem login, técnico, cliente, registro de atividade, contas e busca por chaves secretas no código.
Regras de acesso do banco (políticas)	OK	Idênticas no real e no teste. Proteção por linha ativa em todas as tabelas.
Funções e gatilhos do registro de atividade	OK	Idênticos e ativos nos dois projetos.
Função de cadastro de usuários	OK	Mesma versão nos dois projetos e exige login.
Arquivos (fotos e PDFs)	OK	Área privada, limite de 10 MB, só imagens e PDF.
Chaves secretas no repositório público	OK	Nenhuma. O app só usa a chave pública.
Usuários do sistema real	Atenção	Só 1 administrador ativo. Criar um segundo ou definir um plano caso essa pessoa perca o acesso.
Proteção contra senhas vazadas	Atenção	Desligada no Supabase. Ativar no painel de autenticação (pode depender do plano).
Backup automático e restauração	Atenção	O backup automático depende do plano contratado, a confirmar. O app exporta e restaura backups (22/10: dados, sem fotos, PDFs e logins).
Bibliotecas carregadas da internet	Atenção	Não têm verificação de integridade (SRI). Avaliar incluí-la ou hospedar as bibliotecas junto do app. A SheetJS 0.18.5 é antiga; as falhas conhecidas envolvem ler arquivos de terceiros e o app só gera planilhas.
Registro de atividade no sistema real	Vazio	Normal: a nova versão do app ainda não foi publicada e o sistema real ainda não tem movimento.

Resumo: as regras de acesso estão corretas e iguais nos dois ambientes. Os pontos de atenção são de configuração e de rotina (segundo administrador, senhas vazadas, backup, integridade das bibliotecas), não de falhas nas regras.

4. Onde ficam os relatórios

Cada verificação mensal gera um relatório em texto, guardado na pasta `Relatórios de segurança`, fora do repositório público. Assim os pontos de atenção não ficam expostos para quem lê o código.